SIEM-SOAR

SIEM과 SOAR·사고 대응 자동화

연관 기출 · 127-3-6, 135-1-5

한눈에 이해

여러 로그에 서 사건을 찾아 연결하는 일과, 그 사건에 대해 도구·사람의 대응을 조율하는 일을 이어 붙입니다.

정의와 핵심 원리

SIEM은 보안이벤트를 수집·정규화·상관분석·검색하여 탐지와 조사를지원합니다. SOAR는 여러 보안도구·절차·사람을 플레이북으로연결하고 반복대응을 자동화·기록하는기능군입니다.

• SIEM은 시간 동기·자산·사용자문맥·로그 품질·규칙튜닝이핵심입니다. 수집량증가만 으로탐지 효과가 커지지않으며누락·오탐·저장 비용·프라이버시를 관리합니다. 전술·기법에 연결된탐지로 유효성을시험합니다.

• SOAR는 경보수신 → 중복제거·강화정보조회 → 분류·우선순위 → 승인/자동조치 → 티켓·증거 기록 → 종결·피드백을구성합니다. IP차단·계정비활성화같은 행위는 업무 영향·확신도·승인 기준·롤백·타임아웃이 필요합니다.

• 구성은오케스트레이션연계·자동화엔진·사건/케이스관리·위협 정보등으로설명할 수 있습니다. 기대효과는 반복시간단축·일관성·증거추적이며 실제 MTTD/MTTR·오탐·재오픈·자동조치실패로검증합니다. 자동화 대상과 사람의 판단경계를 명확히합니다.

• 도구 연계용 계정과 API 토큰도 최소 권한·회전·실행감사를 적용하여 자동화 플랫폼의 권한집중을 줄입니다.

구조·비교·판단

구분	핵심 원리	적용·한계
SIEM	로그 수집·상관·탐지	이벤트 품질·탐지튜닝
SOAR	도구·플레이북·대응	승인·권한·롤백
공통	사건문맥과감사	연계 API·운영 책임

적용 예제

피싱 메일 플레이북

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: 직원신고메일의URL평가필요

1. 원본과 헤더를보존하고 안전한 환경에 서 평판·관측을조회합니다.
2. 동일메일수신범위를 검색합니다.
3. 확신도와업무 영향에 따라 승인후메일격리·도메인차단합니다.
4. 조치 결과·예외·복원을 기록하고 탐지 규칙을 보완합니다.

결과·해석: 자동화속도와잘못된광역차단 위험을 함께 관리합니다.

전제·주의: 플레이북은 조직의 권한·절차·업무 영향에 맞춰 시험해야 하며 자동 차단의 효과를 보장하지 않습니다.

답안 골격과 혼동 방지

등장배경 → 수집 → 대응 구조 → SIEM/SOAR비교 → 플레이북예 → 도입·효과 측정

- SOAR가 SIEM이나 분석가 를완전히대체한다고쓰지않습니다.
- 모든 경보를 무승인 차단으로 연결하지 않습니다.

내용을 가리고 회상

1. 오케스트레이션과자동화는 무엇이다릅니까?
2. 위험한조치의승인 기준은 무엇입니까?
3. 효과 측정에 오탐도포함해야 하는이유는무엇입니까?

적용 기준과 근거

Microsoft 공식 SOAR 설명(2026-05-26)과 NIST/MITRE 근거로 원리·비교·운영을 확인했습니다. 제조사의 효과 주장을 보편 성과 수치로 옮기지 않았습니다.

내용 검토 상태: 출처 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- What is SOAR? - Microsoft Security; 2026-05-26 갱신; 확인 2026-11-05.
- MITRE ATT&CK TA0008 Lateral Movement - MITRE; 최종수정 2025-08-11; 확인 2026-11-05.
- NIST SP800-86 Integrating Forensics into Incident Response - Karen Kent et al. / NIST; 2006-08; 확인 2026-11-05.